Informe Técnico de Laboratorio: Inundación TCP SYN Flood (DoS) y Mitigación Defensiva SOC.

Este informe de laboratorio técnico documenta la simulación controlada, inspección forense y respuesta de seguridad ante un ataque de Denegación de Servicio (DoS) por Inundación TCP SYN (SYN Flood). El documento proporciona una guía exhaustiva para analistas defensivos de ciberseguridad (Blue Team) y operadores de un Centro de Operaciones de Seguridad (SOC), detallando los procedimientos operativos desde la generación del vector de saturación en la Capa 4 hasta la implementación de contramedidas en el Kernel de Linux y la infraestructura de firewall.

1. Contexto Técnico y Objetivos de la Práctica.

El protocolo de transporte TCP (Transmission Control Protocol) establece conexiones punto a punto mediante el mecanismo de intercambio de tres vías (*Three-Way Handshake*), el cual consta de tres fases consecutivas: envio de solicitud SYN, respuesta de confirmación SYN-ACK por parte del servidor, y envio final de confirmación ACK por parte del cliente.
En una inundación TCP SYN, el atacante explota la arquitectura de reserva de memoria de la cola de conexiones pendientes (*SYN Queue*). Al transmitir una cantidad masiva de paquetes SYN utilizando direcciones IP de origen suplantadas (*IP Spoofing*) o descartando las respuestas, el servidor destino agota su capacidad de procesamiento de memoria para sockets en estado SYN_RECV. Como consecuencia directa, el sistema operativo rechaza cualquier solicitud legitima entrante, vulnerando el pilar de **Disponibilidad** de la Triada CIA.

Objetivos Principales del Laboratorio:

- **Simulación ofensiva controlada** : Generar una ráfaga volumétrica de paquetes TCP SYN utilizando la herramienta hping3 sobre un servicio HTTP expuesto en el puerto 80.
- **Auditoría de pila de red** : Inspeccionar la saturación de memoria del Kernel en la máquina objetivo mediante comandos de terminal (netstat / ss).
- **Análisis de firma de tráfico** : Detectar y aislar la huella de red del ataque en Wireshark aplicando filtros booleanos de capa de transporte.
- **Respuesta y mitigación SOC** : Implementar la tecnología de TCP SYN Cookies a nivel del sistema operativo y establecer límites de frecuencia de conexión mediante reglas de iptables.

Contexto de Incidentes Reales:

En 2018, la plataforma de desarrollo GitHub sufrió uno de los mayores ataques de denegación de servicio registrados en la historia, alcanzando un pico de tráfico de 1.35 Tbps. Aunque el vector principal incluyó amplificación por vectores Memcached en la capa de aplicación, las capas secundarias y de ataque previo utilizaron mecanismos de inundación TCP SYN orientados a colapsar las tablas de seguimiento de estado (*Connection Tracking / conntrack*) en los balanceadores de carga frontales.

2. Fase 1: Ejecución Controlada del Ataque TCP SYN Flood con hping3.

La herramienta hping3 es un ensamblador y analizador de paquetes TCP/IP orientado a pruebas de estrés, auditorías de seguridad y evaluación de reglas de firewall. Permite enviar paquetes arbitrarios modificando las cabeceras de red.

2.1. Comandos y Sintaxis de Ejecución

Desde la máquina atacante Kali Linux, se lanza la ráfaga de paquetes TCP SYN hacia el puerto 80 de la máquina víctima (Metasploitable 2):

```
# Ejecución del ataque volumétrico SYN Flood sobre el puerto 80 del objetivo
sudo hping3 -S --flood -V -p 80 <IP_VICTIMA>
```

2.2. Desglose de Parámetros Técnicos

- **sudo** Privilegios de Superusuario: Requerido para construir y transmitir sockets crudos (raw sockets) en la Capa de Red.
- **-S** Flag SYN Activado: Establece el bit SYN (0x02) en la cabecera TCP para solicitar la apertura de una nueva sesión.
- **--flood** Modo Inundación: Transmite paquetes a la máxima velocidad que permita la tarjeta de red, omitiendo la lectura de respuestas.
- **-V** Output Verbose: Activa la salida detallada en consola para visualizar las cabeceras y parámetros transmitidos.
- **-p 80** Puerto Destino: Dirige el tráfico malicioso al servicio web HTTP expuesto en el servidor receptor.

🧠 Sin rodeos:

¿Qué hace exactamente este comando?

El comando hping3 actúa como una metralleta de llamadas telefónicas. Con el parámetro -S indica que quiere iniciar una llamada, con -p 80 marca la extensión del departamento de atención al cliente (servidor web), y con --flood aprieta el gatillo para marcar miles de veces por segundo sin esperar a que el receptor diga *"hola"* .

¿Qué se observa en la pantalla?

En la consola de Kali Linux verás el mensaje **hping stopped -- flood mode enabled!**. La pantalla no mostrará respuestas individuales porque la herramienta está ocupando el 100% del procesamiento en enviar tráfico lo más rápido posible.

3. Fase 2: Monitoreo de Sockets Semiabiertos y Estado del Kernel.

Cuando los paquetes SYN ingresan al servidor víctima, el Kernel de Linux procesa las peticiones y almacena cada socket en una estructura de memoria temporal dentro de la cola de conexiones.

3.1. Inspección de Sockets con netstat

En la máquina objetivo (Metasploitable 2), se ejecuta el siguiente comando para evaluar la cantidad y estado de las conexiones activas:

```
# Listar sockets TCP en estado de espera SYN_RECV
```

```
netstat -tna | grep SYN_RECV

# Contar numéricamente las entradas retenidas en memoria
netstat -tna | grep SYN_RECV | wc -l
```

(En distribuciones Linux modernas, se puede emplear el comando ss -tan state syn-recv).

3.2. Evaluación de Resultados e Impacto en Memoria

1. **Estado SYN_RECV** : Indica que el servidor recibió la petición SYN, envió el paquete de confirmación SYN-ACK al cliente, y se encuentra retenido a la espera del paquete ACK final.
2. **Saturación de la Cola (*SYN Queue Exhaustion*)** : El valor retornado por wc -l se incrementa exponencialmente hasta alcanzar el límite máximo asignado por la variable del Kernel net.ipv4.tcp_max_syn_backlog.
3. **Colapso de Conexiones Legítimas** : Una vez alcanzado el umbral del backlog, el sistema rechaza los nuevos paquetes SYN, provocando tiempos de espera agotados (*connection timeout*) para los usuarios legítimos.

🧠 Sin rodeos:

¿Qué significan los resultados de netstat?

netstat -tna | grep SYN_RECV es la herramienta con la que el administrador del servidor mira la lista de espera de la memoria. Si la salida muestra cientos o miles de líneas que dicen SYN_RECV, significa que el servidor tiene todas sus "libretas de notas" llenas con llamadas incompletas.

¿Por qué colapsa el sitio web?

Porque la memoria del servidor reservada para recibir nuevos clientes tiene un límite estricto. Cuando ese límite se llena de conexiones falsas, el servidor simplemente ignora a cualquier persona real que intente entrar al sitio web.

4. Fase 3: Captura de Tráfico y Firma de Red en Wireshark.

El análisis de paquetes mediante un analizador de red (NIDS/PCAP) permite identificar la firma matemática del ataque y diferenciar el tráfico malicioso del tráfico web convencional.

4.1. Filtro de Inspección Forense

Iniciando la captura de paquetes en la interfaz eth- de Kali Linux, se ingresa la siguiente expresión booleana en la barra de filtros de visualización (*Display Filter*):

```
tcp.flags.syn == 1 && tcp.flags.ack == 0
```

4.2. Indicadores de Firma y Análisis de Tráfico

La inspección de paquetes en Wireshark revela las siguientes anomalías características:

- Presencia masiva de paquetes TCP con bit SYN=1 y bit ACK=0.
- Ausencia proporcional de paquetes ACK de retorno desde las direcciones de origen.
- Ratio desproporcionado de peticiones iniciales en comparación con las sesiones TCP efectivamente completadas.

- Variación anómala o aleatorización constante de puertos de origen (*Ephemeral Ports*).

1. **Evaluación de Flags TCP** : La regla evalúa explícitamente los bits de control en la cabecera TCP. La condición syn == 1 aísla las solicitudes de inicio de sesión, mientras que ack == 0 descarta los paquetes que forman parte de una transmisión activa o de la confirmación final.
2. **Análisis de Disparidad de Ratio** : En un entorno operacional saludable, a cada paquete de inicio le sigue una secuencia balanceada de datos y cierres de sesión (FIN / RST). Durante el ataque, la gráfica de I/O en Wireshark muestra una espiga vertical continua de peticiones SYN sin respuesta de cierre.

🧠 Sin rodeos:

¿Qué estamos haciendo en Wireshark?

Wireshark es como poner un detector de metales y una cámara de alta velocidad en la entrada de la red. Al usar el filtro tcp.flags.syn == 1 && tcp.flags.ack == 0, le pedimos a la cámara que nos muestre **únicamente a las personas que levantan la mano para pedir entrada, pero que nunca entran** .

¿Qué demuestra esta prueba forense?

Demuestra sin lugar a dudas que el servidor está sufriendo un ataque malicioso intencional (DoS) y no un incremento de clientes reales, ya que los clientes reales siempre completan la llamada respondiendo con el paquete de confirmación (ACK).

5. Fase 4: Respuesta Defensiva SOC, Mitigación y Marco MITRE ATT&CK.

La fase de respuesta a incidentes requiere aplicar contramedidas inmediatas a nivel del Kernel de Linux y configurar reglas de inspección en el firewall local (iptables) para contener la denegación de servicio.

5.1. Activación de TCP SYN Cookies en el Kernel

Para evitar que el servidor reserve bloques de memoria física al recibir solicitudes SYN, se habilita la función de SYN Cookies mediante el sistema de gestión sysctl:

```
# Habilitar el mecanismo defensivo TCP SYN Cookies en el Kernel
sudo sysctl -w net.ipv4.tcp_syncookies=1
```

Mecanismo de Operación Criptográfica: Cuando las SYN Cookies están activas, el Kernel **no asigna espacio en la memoria (SYN Queue)** al recibir el paquete SYN. En su lugar, calcula un hash criptográfico derivado de la IP de origen, puerto de origen, IP de destino, puerto de destino y un contador de tiempo. Este valor hash se envía codificado dentro del **Número de Secuencia Inicial (ISN)** del paquete SYN-ACK. La memoria para la conexión se reserva únicamente si el cliente responde con un ACK válido que contenga el número de secuencia incrementado.

5.2. Reglas de Filtrado y Control de Tasa en iptables

Para mitigar la ráfaga de tráfico entrante a nivel de firewall, se aplica una regla en iptables que limita la cantidad de conexiones SYN concurrentes permitidas por dirección IP:

```
# Bloquear direcciones IP que superen las 20 conexiones TCP SYN
concurrentes al puerto 80
sudo iptables -A INPUT -p tcp --syn --dport 80 -m connlimit
--connlimit-above 20 -j DROP
```

5.3. Matriz de Mapeo MITRE ATT&CK y Contramedidas

Categoría: Mapeo MITRE ATT&CK
Elemento de Análisis / Control: Táctica
Clasificación / Comando Operativo: Impact (Impacto en la Disponibilidad)

Categoría: Mapeo MITRE ATT&CK
Elemento de Análisis / Control: Técnica
Clasificación / Comando Operativo: Network Denial of Service: Direct Volume Flood (Código T1498.001).

Categoría: Mitigación Kernel
Elemento de Análisis / Control: Control de Memoria
Clasificación / Comando Operativo: `sysctl -w net.ipv4.tcp_syncookies=1` (Elimina la preasignación en SYN Queue)

Categoría: Mitigación Firewall
Elemento de Análisis / Control: Límite por IP
Clasificación / Comando Operativo: iptables -A INPUT -p tcp --syn --dport 80 -m connlimit --connlimit-above 20 -j DROP

🧠 Sin rodeos:

¿Cómo resuelven el problema las SYN Cookies y el Firewall?

1. **SYN Cookies (sysctl)** : Es como si el recepcionista del banco dejara de usar la libreta de reservas. Ahora, a cada persona que llama le entrega un ticket con una clave matemática encriptada. Si la persona no se presenta físicamente en la ventanilla con ese ticket, el banco no gastó ni un solo segundo de su tiempo ni un centímetro de su papel.
2. **Firewall (iptables)** : Es como poner un guardia de seguridad en la puerta de la central telefónica. Si nota que un mismo número de teléfono intenta llamar más de 20 veces seguidas para pedir turnos, el guardia le cuelga la llamada automáticamente antes de que entre al sistema.

¿Cuál es el resultado final?

El servidor web vuelve a responder a los usuarios legítimos de inmediato, neutralizando por completo el ataque de denegación de servicio a pesar de que el atacante continúe enviando paquetes.